Seguridad y Calidad en el Desarrollo (CDY2203)

Informe escrito

Índice

Título(Arial 22 negrita) ..... **Error! Bookmark not defined.**

Subtítulo (Arial 16 negrita)..... **Error! Bookmark not defined.**

Seguridad y calidad semana 3

Despliegue de una arquitectura de microservicios mediante Docker y ejecución de pruebas de seguridad con OWASP ZAP.

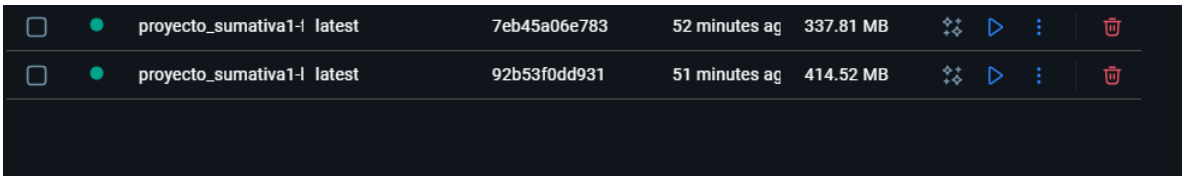
Pasos en la elaboración del proyecto

1. Preparación del Entorno y Generación de Imágenes

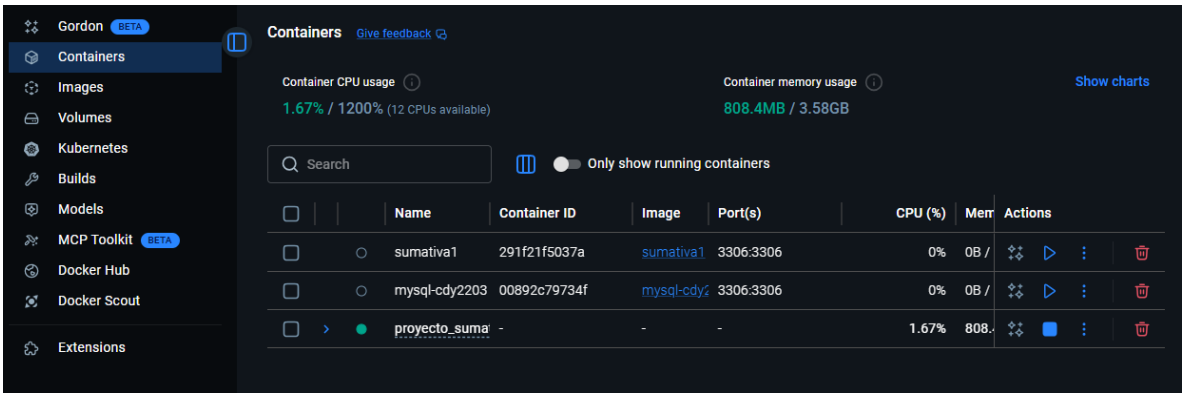
El proceso comenzó con la configuración del entorno de contenedores. Se utilizaron archivos Dockerfile específicos para las capas de frontend y backend, permitiendo la portabilidad de la aplicación.

- **Generación de imágenes:** Se ejecutaron los comandos de construcción para empaquetar la lógica de negocio (Spring Boot) y la interfaz de usuario.

Imágenes



Contenedor



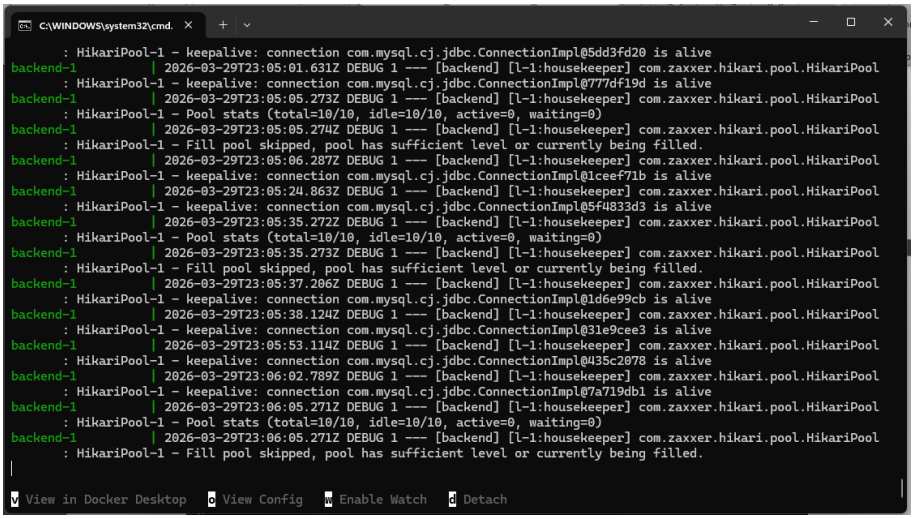
2. Orquestación y Despliegue con Docker Compose

Para asegurar que los servicios de Backend, Frontend y la base de datos MySQL interactúen correctamente, se utilizó Docker Compose.

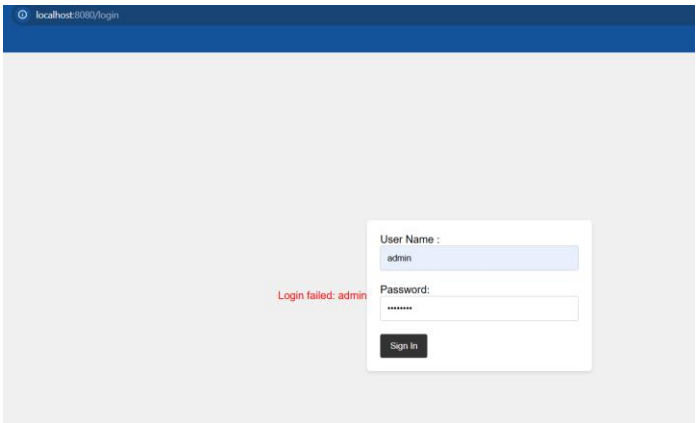
- **Habilitación de contenedores:** Se levantaron los servicios de forma orquestada, asegurando que la base de datos estuviera disponible para las conexiones del backend.

- **Verificación de despliegue:** Se confirmó que ambos servicios (puertos 8080 y 8081) estuvieran operativos.

Despliegue de fronted y backend



Login de acceso

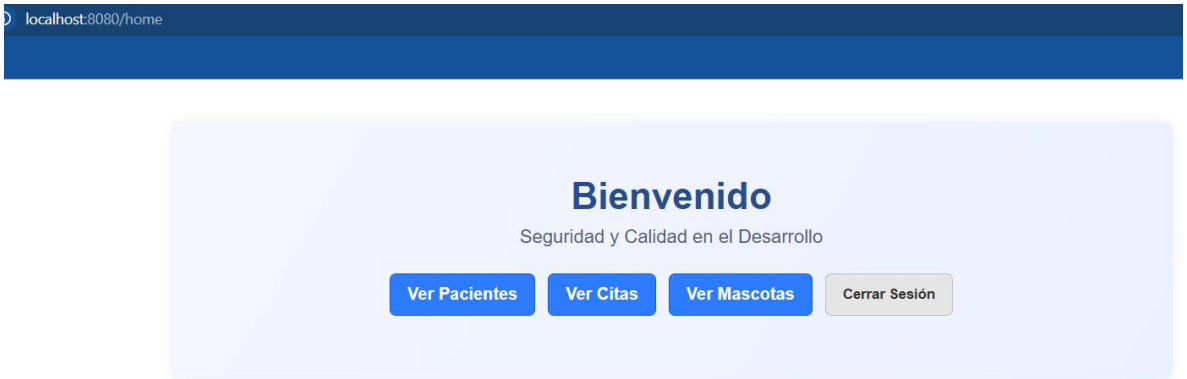


3. Acceso y Funcionalidades de la Aplicación

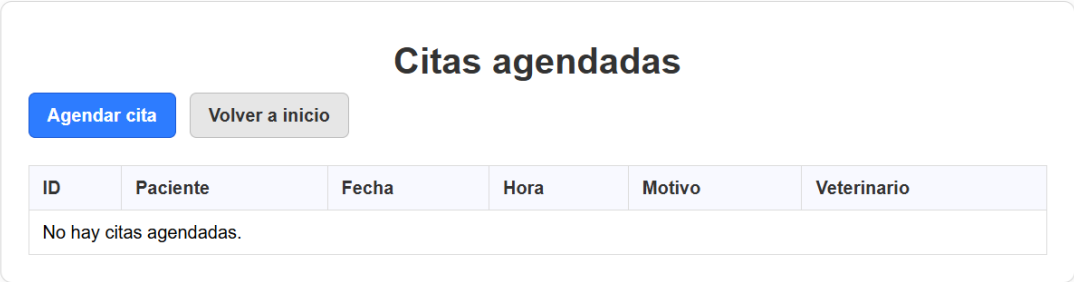
Tras solucionar problemas iniciales de acceso, se procedió a la validación de las funcionalidades principales de la aplicación de veterinaria "VetApp".

- **Autenticación:** Se ingresó al sistema utilizando las credenciales preconfiguradas (**Usuario:** user / **Clave:** password).
- **Gestión de Datos:** Se realizaron pruebas exitosas en los módulos de:
    - Registro de mascotas y pacientes.
    - Gestión y registro de citas veterinarias.
- **Base de Datos:** Se verificó la persistencia de los datos mediante la conexión de **DBeaver** a la instancia de MySQL en el puerto 3306.

Ingreso a la app post creación de usuarios con el usuario: user clave: password

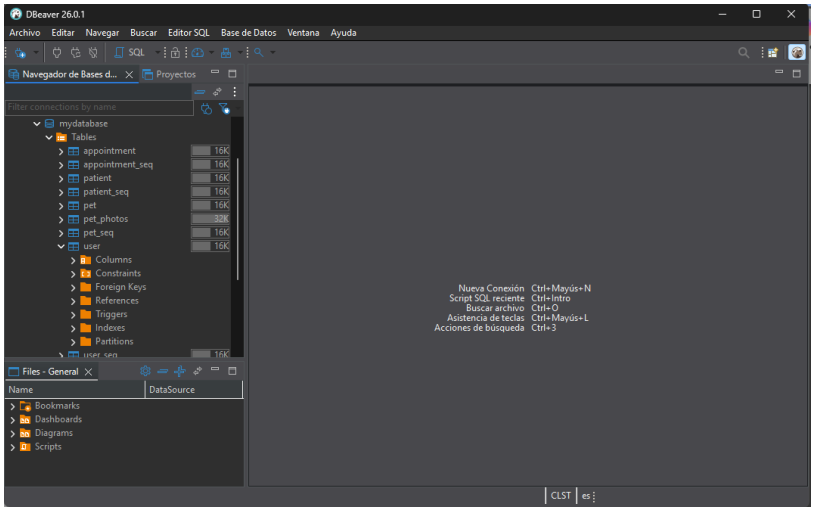


Registro de citas



Registro de pacientes

Despliegue base de datos en Dbeaver

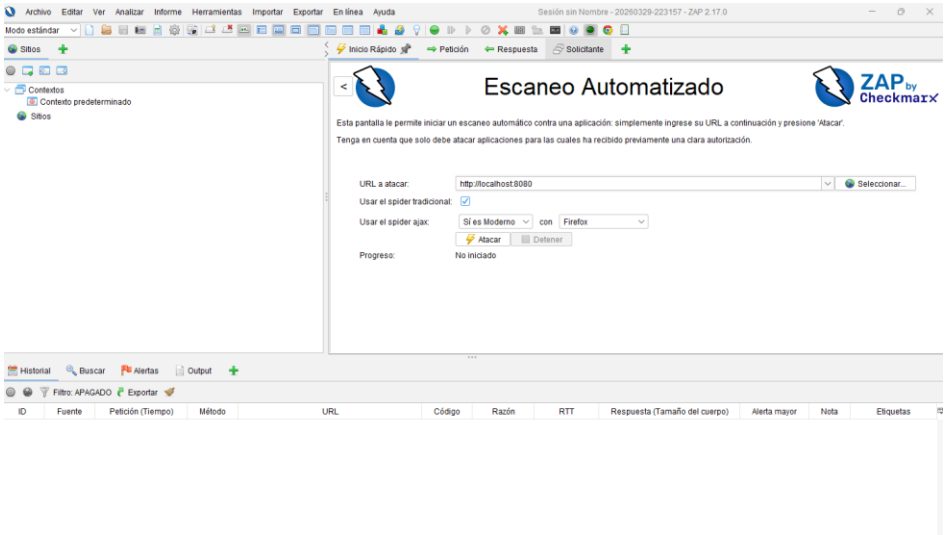


4. Análisis de Seguridad con OWASP ZAP

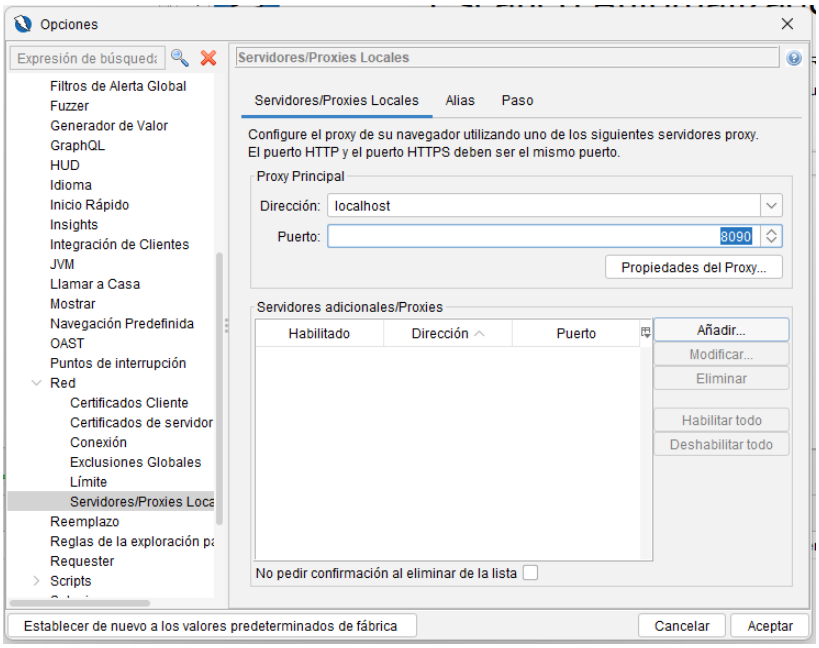
Como parte fundamental del aseguramiento de la calidad, se realizó un análisis de vulnerabilidades sobre el frontend desplegado en localhost:8080.

- **Configuración del Escaneo:** Se configuró ZAP para realizar un escaneo automatizado. Para evitar conflictos de puertos, se cambió el puerto de escucha de la herramienta al **8090**.
- **Ejecución del Ataque:** Se lanzó un ataque activo para identificar debilidades en las cabeceras HTTP y posibles puntos de inyección.

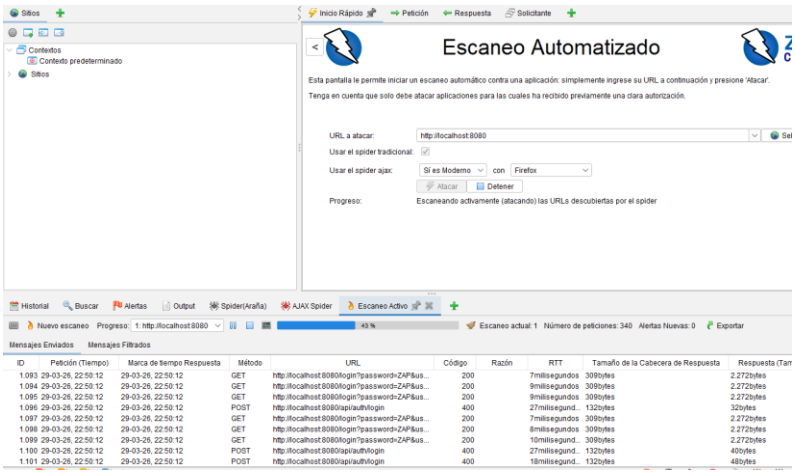
Escaneo automático de ZAP, ingresando la URL: localhost:8080



Cambiar puerto de nombre al 8090



Se realiza el ataque a la app desplegada



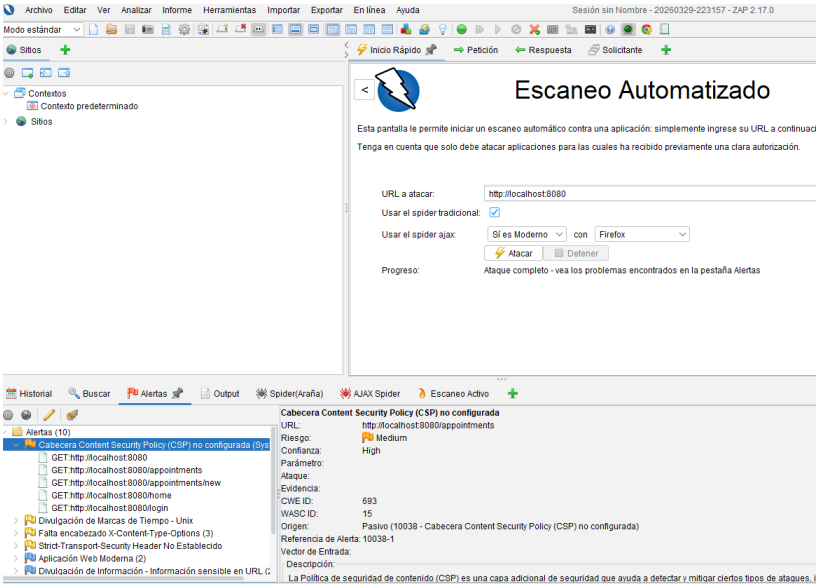
5. Resultados y Hallazgos de Seguridad

El escaneo arrojó diversas alertas de seguridad que deben ser gestionadas para cumplir con los estándares de calidad.

- **Vulnerabilidades Detectadas:** Se identificaron múltiples riesgos, destacando problemas de configuración en las cabeceras de respuesta.
- **Análisis de Riesgo Medio:** Se detectó la falta de la cabecera **Content Security Policy (CSP)**, lo que aumenta el riesgo de ataques XSS.

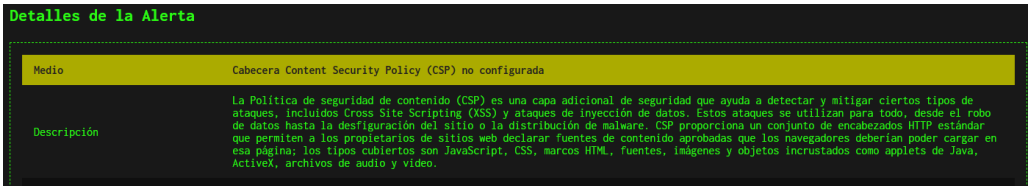
- **Solución Propuesta:** Según el informe de ZAP, la solución implica configurar el backend para enviar políticas de seguridad que restrinjan el origen de los scripts permitidos.

Finalmente el resultado del ataque realizado con la presencia de las vulnerabilidades



Generación de informe de vulnerabilidades

Problema de riesgo medio



Solución sugerida por ZAP para este problema

Conclusión

El despliegue fue exitoso, logrando la integración total de la arquitectura. Sin embargo, el análisis de **ZAP** demuestra que la aplicación requiere ajustes en sus políticas de seguridad (cabeceras HTTP) para mitigar riesgos de nivel medio antes de un despliegue en producción.

Reservados todos los derechos Fundación Instituto Profesional Duoc UC. No se permite copiar, reproducir, reeditar, descargar, publicar, emitir, difundir, de forma total o parcial la presente obra, ni su incorporación a un sistema informático, ni su transmisión en cualquier forma o por cualquier medio (electrónico, mecánico, fotocopia, grabación u otros) sin autorización previa y por escrito de Fundación Instituto Profesional Duoc UC
La infracción de dichos derechos puede constituir un delito contra la propiedad intelectual.